CloudVault: Design and Implementation of an Attack-Resistant Enterprise Platform

CYC386 — Secure Software Design and Development | Midterm DevSecOps Sprint Report
Department of Computer Science, COMSATS University Islamabad (Fall 2026)
Instructor: Engr. Muhammad Ahmad Nawaz
Authors: Muhammad Tallat (FA23-BCT-029), Sadat Ali (FA23-BCT-034), Hassaan Shakoor (FA23-BCT-054)

Abstract

This report presents the complete security engineering lifecycle for CloudVault, an attack-resistant enterprise collaboration portal. We conducted Protection Needs Elicitation, systematic STRIDE threat modeling, and quantitative CVSS v3.1 risk scoring. We identified, demonstrated in a controlled lab environment, and remediated five mandatory vulnerability classes: Buffer Overflow (CWE-120), OS Command Injection (CWE-78), IDOR (CWE-639), CSRF (CWE-352), and Clickjacking (CWE-1021). Our architecture integrates native compiler mitigations, a GitHub Actions CI/CD pipeline with automated SAST and DAST gates, and Docker containerization. All work items maintain full traceability across Jira, Git branches, PR reviews, and automated verification tests.

1. System Architecture

CloudVault comprises a Python/Flask web presentation layer, an SQLite database, an isolated native C metadata parser (`libparser_secure.so`), and a centralized security layer (`app/security.py`). The system enforces strict trust boundaries between client requests, application processing, and underlying host system calls.

2. Protection Needs Elicitation (PNE) & CIA Triad Mapping

All assets (DA-01 to DA-04, PA-01 to PA-05, CA-01 to CA-04) were mapped to Confidentiality, Integrity, and Availability. Key requirements include object-level authorization (SR-02), synchronizer anti-CSRF tokens (SR-03), parameterization without shell interpretation (SR-04), native memory bounds checking (SR-05), and clickjacking frame prevention (SR-06).

3. Threat Modeling & CVSS v3.1 Scoring

Threats were analyzed across DFD Level-1 processes: Command Injection (CVSS 9.9 Critical), Native Buffer Overflow (CVSS 8.8 High), IDOR (CVSS 6.5 Medium), CSRF (CVSS 6.5 Medium), and Clickjacking (CVSS 4.3 Medium). Prioritized mitigations were tracked in Jira sprint issues CV-10 through CV-30.

4. Core Vulnerability Remediation

• **Buffer Overflow (CWE-120):** Replaced unbounded `strcpy()` with bounded `memcpy` and `snprintf`. Enforced `CVLT` magic bytes and payload limits. Enabled `-fstack-protector-strong`, `-D_FORTIFY_SOURCE=2`, ASLR, and NX.
• **Command Injection (CWE-78):** Eliminated `os.popen()` and shell interpretation. Implemented `subprocess.run(shell=False)` with argument arrays and a strict regex whitelist (`^[a-zA-Z0-9.-]+$`).
• **IDOR (CWE-639):** Implemented centralized tenancy verification in `check_document_access()`. Unauthorized access returns HTTP 403 Forbidden.
• **CSRF (CWE-352):** Implemented the Synchronizer Token Pattern with constant-time token comparison and configured cookies with `SameSite=Strict`.
• **Clickjacking (CWE-1021):** Applied global middleware injecting `X-Frame-Options: DENY` and CSP `frame-ancestors 'none'` headers.

5. Automated CI/CD Pipeline, SAST & DAST Testing

Our GitHub Actions pipeline (`ci-cd.yml`) enforces build compilation, 27 automated `pytest` test cases, Bandit SAST analysis, and dynamic DAST baseline scanning. Pre-remediation scans showed 1 High SAST finding and 2 High DAST findings. Post-remediation scans pass cleanly with 0 High or Critical findings.

6. Individual Contribution Statement

• **Muhammad Tallat (FA23-BCT-029):** Lead Architect & Core Engineer — Designed database models, authentication, IDOR access controls, and CSRF token verification. Authored PNE report.
• **Sadat Ali (FA23-BCT-034):** AppSec & Threat Modeling Engineer — Implemented native C parser, memory bounds checking, compiler flags in Makefile, Clickjacking headers, and Threat Model.
• **Hassaan Shakoor (FA23-BCT-054):** DevSecOps & QA Automation Engineer — Remediated Command Injection, developed 27 automated test cases, configured GitHub Actions CI/CD, and created Docker containerization.